

# Incident Report Analysis

*Denial-of-Service (ICMP flood) incident — analyzed using the NIST Cybersecurity Framework (CSF)*

## Summary of the Security Event

|                              |                                                                                                                                                                                                                                                              |
|------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Date/Time of incident</b> | Business hours, approximately mid-morning; incident lasted roughly two hours before resolution.                                                                                                                                                              |
| <b>Organization</b>          | A multimedia company that provides web design, graphic design, and social media marketing services to small-business clients.                                                                                                                                |
| <b>Attack type</b>           | Denial-of-Service (DoS) attack carried out via an ICMP flood (ping flood).                                                                                                                                                                                   |
| <b>Cause</b>                 | A malicious actor sent a high-volume flood of ICMP ping packets into the company's network through a firewall that had not been properly configured to limit or filter this type of traffic.                                                                 |
| <b>Targeted systems</b>      | The organization's internal network and the firewall protecting it. The flood consumed network resources broadly, rather than targeting a single server or application.                                                                                      |
| <b>Impact</b>                | Internal network services stopped responding for approximately two hours. Employees could not reach network resources needed to do their jobs, halting normal business operations for the duration of the incident.                                          |
| <b>Response taken</b>        | The incident management team blocked incoming ICMP packets, took non-critical network services offline to preserve capacity for critical systems, and restored critical services. The security team then traced the root cause to the unconfigured firewall. |

## Identify

*Identify security risks through regular audits of internal networks, systems, devices, and access privileges to find potential gaps in security.*

**Type of attack:** This was a Denial-of-Service (DoS) attack using an ICMP flood. A single source overwhelmed the network with ping requests faster than it could process them, exhausting network resources and blocking legitimate traffic.

### Systems and assets impacted:

- The perimeter firewall, which lacked a rule to limit or filter the volume of incoming ICMP traffic — this was the root vulnerability that allowed the attack through.
- The internal network as a whole: normal traffic could not reach network resources for the duration of the attack.
- Employee productivity and client-facing services (web design, graphic design, social media marketing delivery), since staff lost access to the systems needed to do their work.

Root cause / gap identified: an unconfigured firewall with no ICMP rate limiting and no source-IP verification, discovered through the post-incident investigation rather than a proactive audit — highlighting the need for regular firewall configuration reviews going forward.

## Protect

*Protect internal assets by implementing policies, procedures, training, and tools that help mitigate cybersecurity threats.*

- Formalize the firewall rule limiting the rate of incoming ICMP packets that the team already implemented, and document it in the network's baseline configuration so it survives future changes.
- Enable source IP address verification on the firewall to detect and drop spoofed ICMP packets, as already put in place after the incident.
- Establish a recurring firewall and network device configuration audit (e.g., quarterly) so misconfigurations like the missing ICMP rule are caught proactively instead of after an incident.
- Introduce a change-management process requiring peer review and sign-off before firewall or network configuration changes go live.
- Segment the network so that a flood or compromise affecting one segment (e.g., guest or non-critical services) cannot exhaust resources needed by critical systems.
- Provide regular security awareness and configuration-hardening training for the network/IT team responsible for firewall management.

## Detect

*Detect potential security incidents and improve monitoring capabilities to increase the speed and efficiency of detection.*

- Deploy and tune the network monitoring software already introduced after the incident to establish a baseline of normal traffic volume, so sudden spikes (like an ICMP flood) trigger an alert automatically rather than being noticed only once services fail.
- Configure the IDS/IPS system to flag and filter ICMP traffic with suspicious characteristics — e.g., abnormal packet rate, packet size, or a high volume from a single source — and route those alerts to the security team in real time.
- Set threshold-based alerting (packets-per-second or bandwidth thresholds) on the firewall and monitoring tools so responders are notified within minutes of an anomaly, not hours.
- Track authorized versus unauthorized device and user activity on the network, and flag unusual account behavior (e.g., logins or access attempts outside normal patterns) that could indicate a related or follow-on attack.
- Review network and firewall logs on a regular cadence (e.g., daily spot checks, weekly full review) rather than only after an incident is reported.

## Respond

*Respond by containing, neutralizing, and analyzing security incidents, and implement improvements to the security process.*

- Containment: Immediately rate-limit or block incoming ICMP traffic at the firewall (as the team already did), and take non-critical services offline first to preserve capacity for critical systems while the incident is triaged.
- Neutralization: Identify and block the source IP address(es) generating the flood, and confirm the offending traffic has stopped before beginning to restore services.

- Analysis: Collect and preserve firewall logs, packet captures, and monitoring data from the incident window to confirm the attack type, source, and root cause (the unconfigured firewall) — the same analysis that produced the findings in this report.
- Communication: Notify internal stakeholders (leadership, affected teams) and, if client-facing services were disrupted, provide clients with a clear, timely status update.
- Process improvement: Document this incident as a formal playbook entry for “ICMP flood / DoS” so future responders have clear, pre-approved steps — rather than improvising — and define roles and escalation paths in advance. Run a tabletop exercise using this scenario to test the playbook.

## Recover

*Recover affected systems to normal operation and restore systems, data, and/or assets affected by an incident.*

- Confirm that all critical network services, already restored during the incident, are fully functional and that the ICMP flood traffic has not resumed before restoring remaining non-critical services.
- Validate the integrity of systems and data touched during the incident — a DoS attack does not typically alter data, but confirming this (rather than assuming it) should be a standard recovery step.
- Restore non-critical services in a controlled, prioritized order once critical systems and the network are confirmed stable, monitoring closely for any recurrence.
- Hold a post-incident review with the incident management and security teams to capture lessons learned and confirm the Protect/Detect improvements above are actually implemented, not just planned.
- Update the organization's business continuity and incident response documentation to reflect the new firewall rules, monitoring tools, and playbook so the response is faster if a similar incident recurs.
- Communicate resolution and any relevant remediation timeline to affected clients to maintain trust and transparency.